ASSIGNMENT-1

ITA1434 – Ethical Hacking

Item	Detail
Student name	A.Sravanthi
Reg No	192325071
Faculty	Dr.S.Parthiban
Date	3 November 2026
Course Name	Ethical Hacking

Scenario — University Authorized Security-Assessment Programme

A university is establishing an Authorized Security-Assessment Programme to test the security of its student portal, learning-management system, email service and campus network before a major upgrade.The programme must cover approximately 20 systems and 50 staff initially, but the framework is expected remain usable as the programme grows to the whole university and begins to include external, third-party assessors.

The management has not yet fixed how ethical-hacking engagements will be governed. Testing may be requested by different departments, carried out by internal staff or external testers, and may touch systems that hold personal data. The team is concerned that an unstructured approach may lead to unauthorized access, legal exposure, damage to live systems, unclear scope or uncoordinated disclosure of discovered vulnerabilities.

TASK 1 – Formulate the Enquiry and Framework Blueprint 4 Marks

• Convert the scenario into a formal set of engagement-governance requirements. Identify the systems

in scope, the stakeholders, the expected activities and the constraints.

• Create a framework blueprint showing how authorization, scope, legal compliance, threat modelling,

lab testing and disclosure will cooperate in the proposed programme.

• Formulate at least four enquiry questions that your framework must answer, such as who authorizes a test, what is in scope, which laws apply and how findings are disclosed.

• Define at least five design criteria and use them as acceptance criteria for the final framework.

Evidence Expected

A requirements-to-governance blueprint, enquiry questions, design criteria and a clear rationale showinghow the proposed framework addresses the scenario.

TASK 1 – Formulate the Enquiry and Framework Blueprint (4 Marks)

1.1 Requirements Identification

Requirement	**Description**
Systems	Student portal, learning-management system (LMS), university email and campus network.
Initial scale	Approximately 20 systems and 50 staff members.

Stakeholders	University management, system owners, IT security team, legal/privacy officer, internal testers and external assessors.
Activities	Authorization, scope definition, threat modelling, lab testing, vulnerability reporting and remediation.
Constraints	No unauthorized testing, no unnecessary access to personal data and no unapproved disruption of services.
Future expansion	Reusable templates, a central engagement register and role-based approvals.

1.2 Framework Blueprint

The proposed framework follows these steps:

1. **Request:** A department submits a security-assessment request.
2. **Authorization:** The system owner and required university authorities approve the engagement.
3. **Scope definition:** In-scope assets, testing methods, dates and prohibited activities are documented.
4. **Legal review:** Applicable laws, privacy obligations and third-party permissions are checked.
5. **Threat modelling:** Relevant attacker types, motivations and potential targets are identified.
6. **Lab testing:** Approved hands-on activities are conducted in an isolated virtual environment.
7. **Finding management:** Vulnerabilities are documented with evidence, severity and recommendations.
8. **Responsible disclosure:** Findings are privately communicated to authorized stakeholders.
9. **Remediation and closure:** Fixes are verified, records are completed and lessons are documented.

1.3 Enquiry Questions

1. Who is authorized to approve a security assessment?
2. Which systems and testing techniques are included in the approved scope?
3. Which legal and privacy requirements apply?
4. How can likely attackers and their motivations be classified?
5. How should vulnerabilities be reported, fixed and disclosed?

6. How can the framework support future university-wide and third-party assessments?

1.4 Design Criteria and Acceptance Tests

Design criterion	Acceptance test
Authorization	No test begins without valid written approval.
Scope control	Every target matches the approved asset list.
Legal compliance	Required legal and privacy reviews are recorded.
Safety	Testing uses an isolated lab unless separate production approval exists.
Accountability	Approvals, findings and decisions are logged.
Responsible disclosure	Every confirmed finding has an owner and remediation target.
Scalability	Templates and registers support additional systems and assessors.

Rationale: These criteria make the framework measurable. They ensure that testing remains authorized, safe, traceable and suitable for a growing university.

TASK 2 – Design a Hacker Threat Model and Classification 4 Marks

• Design a classification of the types of hackers relevant to the university, such as white-hat, black-hat,grey-hat, script kiddie, hacktivist, insider and state-sponsored actors.

• Map each type to its motivation, typical capability and likely targets within the university.

• Establish clear criteria and naming so that an actor can be classified consistently.

• Demonstrate at least two alternative ways of classifying one borderline actor, then choose and justifythe final classification.

Evidence Expected

A documented hacker threat model, classification criteria, a mapping table, rejected alternatives and a justified final classification.

TASK 2 – Design a Hacker Threat Model and Classification (4 Marks)

2.1 Classification Criteria

Hackers can be classified according to their authorization, motivation, technical capability, targets and observed behaviour. An actor's intentions alone do not determine whether an activity is authorized.

2.2 Hacker Classification Table

Type of hacker	Motivation	Typical capability	Likely university targets
White-hat hacker	Improve security legally	Authorized security testing and reporting	Student portal, LMS and network
Black-hat hacker	Financial gain, theft or damage	Credential theft, malware and exploitation	Student records, email and research data
Grey-hat hacker	Curiosity, recognition or mixed motives	May test systems without permission	Public portal and exposed services
Script kiddie	Experimentation or attention	Uses existing tools with limited understanding	Login pages and exposed services
Hacktivist	Political or social causes	Defacement, information leaks or service disruption	University website and email
Insider	Personal grievance, profit or careless misuse	Misuses legitimate access or internal knowledge	Student databases and administrative systems
State-sponsored attacker	Strategic intelligence or influence	Well-resourced and persistent operations	Research projects and sensitive institutional information

2.3 Borderline Actor Classification

Scenario: A student discovers an exposed LMS page and sends a request to confirm that it is accessible without obtaining written permission.

Alternative classification	Reason	Decision
Grey-hat	The student tests a system without authorization but may have helpful intentions.	Selected as the primary classification.
White-hat	The student later reports the weakness to the university.	Rejected because reporting does not retroactively authorize testing.
Script kiddie	The student uses a simple browser request and has limited technical knowledge.	May be used as a secondary capability description if supported by evidence.

Final decision: Classify the behaviour as grey-hat and the authorization status as unauthorized. Technical capability should be recorded separately. If further evidence shows malicious activity, the classification and risk assessment should be updated.

TASK 3 – Create an Ethics and Code-of-Conduct Module 4 Marks

• Define the ethical principles that govern an authorized engagement, such as written authorization,agreed scope, confidentiality, integrity, avoiding harm and honest reporting.

• Design rules or checks that help detect or prevent unethical actions during an engagement.

• Construct scenario cases containing acceptable, borderline and unacceptable actions and show how the code of conduct responds to each.

• Explain how the module preserves trust and keeps the engagement lawful and professional.

Evidence Expected

A reusable code-of-conduct module, decision rules, scenario test cases and evidence that the rules separate acceptable from unacceptable actions.

TASK 3 – Create an Ethics and Code-of-Conduct Module (4 Marks)

3.1 Ethical Principles

The following principles govern every authorized security assessment.

1. Written authorization: Testing must begin only after valid permission is obtained.
2. Scope discipline: Testers must work only on approved systems and use permitted techniques.
3. Confidentiality: Sensitive university information must not be disclosed to unauthorized persons.
4. Integrity: Testers must not manipulate records, hide activities or falsify results.
5. Avoiding harm: Testing must minimize service disruption and unnecessary risk.
6. Data protection: Only the minimum evidence required should be collected.
7. Honest reporting: Findings must accurately describe the weakness, evidence and limitations.
8. Responsible disclosure: Vulnerabilities must be reported through the approved communication process.
9. Accountability: All activities, approvals and important decisions must be recorded.

10. Professional conduct: Internal and external testers must follow university policies and applicable laws.

3.2 Ethical Decision Rules

- If written authorization is missing or expired, testing must not begin.
- If a target is outside the approved scope, testing must stop until written approval is obtained.
- If personal data is exposed, unnecessary access must stop and the privacy/security team must be notified.
- If a system becomes unstable, the tester must stop and follow the incident-escalation procedure.
- If a finding is uncertain, it must be labelled as suspected rather than confirmed.
- If disclosure may create additional risk, the disclosure coordinator must review the situation before release.

3.3 Scenario-Based Ethical Tests

Scenario	**Classification**	**Required response**
Tester performs approved checks during the permitted window.	Acceptable	Continue and record the activity.
Tester discovers an unlisted server and wants to inspect it.	Not permitted without further approval	Stop and request a scope amendment.
Tester downloads an entire student database to demonstrate a weakness.	Unacceptable	Stop, protect evidence and notify the privacy/security team.
Tester privately reports a confirmed vulnerability.	Acceptable	Create a finding record and initiate remediation.
Tester publishes exploit details before notifying the university.	Unacceptable under programme rules	Escalate to programme management and legal authorities.

Conclusion: The code of conduct separates acceptable security testing from unauthorized or harmful behaviour. It protects university data, maintains trust and ensures professional accountability.

TASK 4 – Construct a Legal-Compliance Mapping 4 Marks

• Map the engagement to the relevant provisions of the Information Technology Act, 2000 on unauthorized access and data, and compare them with an international law such as the Computer Fraud and Abuse Act.

• Build a table of offences, obligations and penalties related to unauthorized access and data protection.

• Connect each legal requirement to a specific control in the engagement framework.

• Decide and justify which legal requirements apply when a test touches systems that hold personal data.

Evidence Expected

A legal-compliance mapping, an offences-and-penalties table, the controls linked to each requirement and a justified conclusion on which laws apply.

TASK 4 – Construct a Legal-Compliance Mapping (4 Marks)

4.1 Applicable Laws and Controls

The framework must be reviewed against applicable Indian law and any relevant foreign law or contractual obligations. The following is an educational summary, not legal advice; current statutory provisions and applicability must be verified by the university's legal officer.

Law or provision	Relevance	Framework control
Information Technology Act, 2000 – Section 43	Certain unauthorized access, copying, damage and related acts can create liability.	Written authorization, strict scope and activity logs.
IT Act – Section 66	Addresses specified Section 43 acts committed dishonestly or fraudulently.	Approval verification, tester accountability and stop-work controls.
IT Act – Section 72	Addresses specified breaches of confidentiality and privacy by persons obtaining access under powers conferred by the Act.	Confidentiality requirements and restricted evidence access.
IT Act – Section 72A	Addresses disclosure of personal information in breach of a lawful contract, subject to the provision's conditions.	Data minimization and contractual data-handling controls.
Digital Personal Data Protection Act, 2023	May apply to digital personal data and relevant processing obligations,	Privacy review, access restrictions, retention

	subject to commencement, applicable rules and exemptions.	controls and incident escalation.
US Computer Fraud and Abuse Act (CFAA), 18 U.S.C. §1030	Addresses specified unauthorized computer access and related conduct under US federal law.	Case-specific legal review for relevant US systems, providers or jurisdictional connections.
Third-party contracts	Cloud and service providers may impose restrictions on security testing.	Obtain required provider permission before testing third-party assets.

4.2 Offences and Penalties: Summary

Provision	**General subject**	**Possible consequence**	**Preventive control**
IT Act Section 43	Unauthorized access and specified harmful acts	Compensation may be payable, depending on the facts and current law.	Signed authorization and scope verification.
IT Act Section 66	Certain Section 43 acts done dishonestly or fraudulently	The provision specifies criminal punishment that may include imprisonment up to three years, a fine up to ₹5 lakh, or both.	Approval checks and complete activity records.
IT Act Section 72	Specified confidentiality/privacy breaches	Statutory punishment may apply if the legal requirements are met.	Confidentiality and evidence-access controls.
IT Act Section 72A	Disclosure of information in breach of lawful contract	Statutory punishment may apply if the legal requirements are met.	Secure storage and contractual restrictions.
CFAA Section 1030	Specified unauthorized access and related conduct	Penalties vary according to the offence and circumstances.	Jurisdictional and provider-permission review.

4.3 Legal Decision for Personal Data

When testing involves systems containing personal data, the university must:

1. Identify the data involved and determine the purpose of testing.
2. Obtain the required legal and privacy review before approval.
3. Minimize access, collection, copying and retention of personal information.
4. Restrict evidence access to authorized personnel.

5. Establish secure storage, retention and deletion procedures.
6. Follow applicable incident-reporting and contractual requirements.
7. Review third-party and cross-border requirements where relevant.

The CFAA should not automatically be assumed to apply to an Indian university engagement. Its applicability depends on the facts and jurisdiction. Legal review must confirm which laws and obligations actually apply.

TASK 5 – Create a Scope and Rules-of-Engagement Document 4 Marks

• Design a scope and rules-of-engagement (RoE) document that defines in-scope and out-of-scope systems, testing windows, permitted and prohibited techniques and escalation paths.

• Create rules for recording and verifying the written authorization behind each engagement.

• Establish clear naming and boundaries so that an out-of-scope request can be detected.

• Construct at least one transformation of the RoE into a pre-engagement checklist.

Evidence Expected

A complete RoE document, authorization-verification rules, scope boundaries and a derived pre-engagement checklist.

TASK 5 – Create a Scope and Rules-of-Engagement Document (4 Marks)

5.1 Rules of Engagement (RoE)

The RoE specifies what the testers may do, where they may do it and when testing must stop.

Field	**Required details**
Engagement ID	Unique ID such as EH-2026-001
Purpose	Security assessment before the university upgrade
Approvers	System owner, security lead and other required reviewers
In-scope systems	Approved student portal, LMS, email and network assets
Out-of-scope systems	Unlisted assets, personal devices and third-party systems without permission
Testing window	Approved start/end dates and permitted times
Permitted techniques	Configuration review, safe discovery and controlled non-destructive checks

Prohibited techniques	Unapproved denial-of-service, destructive tests, malware deployment, persistence and mass data extraction
Data handling	Minimum evidence, restricted access, approved storage and retention period
Emergency contacts	Primary contact, backup contact and escalation route
Stop-work conditions	Service instability, personal-data exposure, scope ambiguity or unexpected impact
Approval record	Signatures, timestamps, scope version and expiry

5.2 Scope Identification and Boundaries

Each asset must have a unique identifier, for example:

- UNI-PORTAL-01 – Student portal
- UNI-LMS-01 – Learning-management system
- UNI-MAIL-01 – University email
- UNI-NET-01 – Campus network

A target is in scope only when its identifier and exact endpoint or network range appear in the active, approved scope document. A neighbouring IP address, redirected hostname or related third-party service is not automatically in scope.

5.3 Authorization Verification Rules

1. Verify the identity and authority of the approver.
2. Check that the engagement ID and scope version match.
3. Confirm that the document contains valid signatures and dates.
4. Verify that the testing window has not expired.
5. Confirm required privacy, legal and third-party permissions.
6. Reject incomplete, expired or contradictory approvals.
7. Require a signed amendment before any scope change.

5.4 Pre-Engagement Checklist

- Request and business purpose recorded.
- System owner and approvers verified.
- Written authorization signed and valid.
- In-scope and out-of-scope assets listed.

- Testing dates and emergency contacts confirmed.
- Permitted and prohibited techniques reviewed.
- Legal, privacy and third-party checks completed.
- Isolated lab and evidence storage verified.
- Stop-work and escalation procedures understood.
- Reporting format and disclosure deadlines agreed.

Conclusion: The RoE prevents scope confusion, reduces legal exposure and provides a consistent checklist before every assessment.

TASK 6 – Build an Authorization and Disclosure Layer 5 Marks

• Create an authorization workflow covering the request, approval, written sign-off and recording of each engagement.

• Design a responsible (coordinated) disclosure process with a reporting format, remediation windowand timeline, and compare it with full disclosure and bug-bounty approaches.

• Develop operations for logging approvals and status updates and for deciding when disclosure may proceed.

• Create rules for choosing between coordinated and full disclosure for a given finding.

• Demonstrate that this layer interacts correctly with the rules-of-engagement and legal-compliance components.

Evidence Expected

An authorization workflow, a responsible-disclosure process, logging and decision operations, disclosure

rules and evidence of interaction with the other components.

TASK 6 – Build an Authorization and Disclosure Layer (5 Marks)

6.1 Authorization Workflow

The authorization workflow ensures that every engagement is formally requested, reviewed, approved and recorded.

1. Request: A department submits its purpose, target systems, data types and preferred dates.
2. Registration: The programme manager creates a unique engagement ID.
3. Review: The system owner and security lead review the scope and technical risks.

4. Legal and privacy check: Required reviewers examine data protection and third-party restrictions.
5. Written approval: Authorized persons sign the authorization form and RoE.
6. Verification: The coordinator checks signatures, dates, scope and permissions.
7. Activation: The engagement becomes approved only after all required checks pass.
8. Monitoring: Testers record activities and report unexpected events.
9. Closure: The final report, remediation status and evidence disposition are recorded.

6.2 Approval and Status Logging

Operation	Input	Expected result
Create engagement	Request form	Unique ID and DRAFT status
Verify authorization	Signed form and RoE	APPROVED or BLOCKED status
Change scope	Requested target/method change	New version requiring approval
Log finding	Finding ID, asset ID and evidence reference	Timestamped finding record
Update disclosure	Finding status and deadline	Updated status and escalation if overdue
Close engagement	Final report and remediation records	CLOSED status after required checks

6.3 Responsible Disclosure Process

Responsible or coordinated disclosure means privately notifying the appropriate organization so that it can investigate and remediate a vulnerability before details are released publicly.

1. The tester reports the finding privately to the university security coordinator.
2. The coordinator acknowledges the report and assigns a finding ID.
3. The finding is verified safely using minimum necessary evidence.
4. The system owner receives the finding and prepares a remediation plan.
5. The coordinator tracks progress against the agreed deadline.
6. The security team verifies the correction.
7. Public disclosure is considered only after a documented safety, legal and privacy review.

Proposed Remediation Timeline

These are internal programme targets, not statutory deadlines.

Severity	Proposed target	Escalation
Critical	Immediate coordination; target mitigation within 72 hours	Immediate notification to the security lead and system owner
High	7 days	Escalate missed deadlines to programme management
Medium	30 days	Follow up with the remediation owner
Low	90 days	Track through routine maintenance

The target may be adjusted through a documented risk decision. Critical and high-severity findings should receive more frequent reviews.

6.4 Comparison of Disclosure Approaches

Approach	Advantages	Limitations	Decision
Coordinated disclosure	Allows the organization to fix the weakness before publication.	Requires timely communication and remediation.	Default approach for the university.
Full disclosure	Makes details immediately available to the public.	May expose users and enable attacks before remediation.	Exceptional use only after documented legal and risk review.
Bug bounty	Encourages external researchers to report vulnerabilities.	Requires funding, eligibility rules, triage capacity and clearly defined scope.	Possible future programme.

6.5 Integration with Other Components

The disclosure process must follow the RoE and legal-compliance requirements. For example, if a finding involves an unlisted system, testing must stop until scope is approved. If personal data is exposed, the privacy officer must be notified. A finding cannot be published automatically just because its remediation deadline has passed.

Conclusion: The authorization and disclosure layer provides accountability from the initial request through final remediation and closure.

TASK 7 – Design an Isolated Ethical-Hacking Lab 5 Marks

• Design a safe, isolated lab using a Kali Linux machine and one or more authorized target machines on a host-only network with reserved addresses such as 192.168.56.0/24.

• Specify the components, roles and connectivity of the lab and the steps used to record itsconfiguration.

• Develop at least two operations, such as verifying connectivity between the machines and recording the lab setup.

• Construct a small comparison between a host-only and a NAT lab network and justify the chosen design.

• Explain how the lab keeps all testing authorized and contained within the isolated environment.

Evidence Expected

An isolated-lab design, a component and connectivity specification, verification operations, a comparison of network options and a justified final lab model.

TASK 7 – Design an Isolated Ethical-Hacking Lab (5 Marks)

7.1 Lab Architecture

The lab uses Kali Linux as the testing machine and an authorized training target as the target machine. Both are connected through a host-only virtual network.

Example network: 192.168.56.0/24

Component	**Example configuration**	**Purpose**
Host computer	VirtualBox or VMware	Runs the virtual machines
Kali Linux VM	192.168.56.10/24	Authorized tester workstation
Target VM	192.168.56.20/24	Isolated training target
Host-only network	192.168.56.0/24	Private communication between VMs
Evidence folder	Restricted local folder	Stores configuration records and test evidence
Optional update connection	Temporary NAT adapter	Allows approved software updates when required

The example subnet must be checked for conflicts with existing networks before use. The target should contain synthetic data rather than real student records.

7.2 Steps to Record Lab Configuration

1. Record the hypervisor name and version.
2. Record each virtual machine's name, operating system and network adapter mode.
3. Record the assigned IP addresses and network subnet.
4. Confirm that the VMs do not have unintended bridged adapters.
5. Take snapshots before testing.
6. Save configuration screenshots and records in the restricted evidence folder.
7. Record the date, operator and configuration version.
8. Restore the snapshots and remove temporary test data after completion.

7.3 Lab Verification Operations

Operation	Procedure	Expected result
Connectivity verification	Check Kali's IP address and test connectivity to 192.168.56.20 using an approved basic connectivity check.	The interface and route correspond to the isolated lab subnet.
Configuration recording	Capture VM settings, IP addresses, adapter modes and snapshots.	A complete lab record is stored.
Containment verification	Check network adapters and routes before testing.	No bridged adapter or unintended connection permits testing of external systems.

A failed ping alone does not prove that isolation is working or that the target is unavailable; the target may block ping. The network configuration must also be inspected.

7.4 Host-Only versus NAT

Feature	Host-only network	NAT network
VM-to-VM communication	Supported	Usually supported, depending on configuration
Internet access	None by default	Outbound access usually available
Exposure risk	Lower for isolated exercises	Additional outbound connectivity must be controlled
Best use	Active security testing	Controlled software updates
Framework decision	Selected for testing	Used temporarily for approved updates, then disabled

7.5 How the Lab Maintains Safety

- Only authorized virtual machines are used.
- Testing is restricted to the private lab subnet.
- No live university system is treated as a lab target.
- Test evidence is securely stored.
- Network configuration is checked before each exercise.
- Any unexpected external connectivity blocks the exercise until corrected.

Conclusion: The host-only lab provides a controlled and repeatable environment for hands-on learning without exposing university production systems.

TASK 8 – Develop a Reusable Document Library 4 Marks

• Create a minimum of four reusable engagement documents supporting the framework, including at least one authorization form and one finding report.

• Use sensible default fields where appropriate and explicitly design the content of each document.

• At least one document, such as the finding report, must produce a structured output that integrates with another component of the framework.

• Create test entries that demonstrate valid, boundary and invalid inputs and document the expected result.

Evidence Expected

A reusable document library, documented fields, a structured report output, test entries and evidence of integration with the framework.

TASK 8 – Develop a Reusable Document Library (4 Marks)

The framework uses reusable documents to maintain consistency across departments and engagements.

8.1 Document A: Authorization Form

Field	Description
Engagement ID	Unique identifier such as EH-2026-001
Requester	Name, role and department
System owner	Person responsible for the asset
Purpose	Reason for the assessment

Scope	Approved asset IDs and endpoints
Testing window	Start date, end date and approved times
Permitted methods	Authorized testing activities
Data sensitivity	Classification and privacy review
Third-party permission	Provider approval reference where required
Signatures	Required approvers and approval dates
Status	DRAFT, UNDER REVIEW, APPROVED, BLOCKED or CLOSED

8.2 Document B: Rules-of-Engagement Record

This document contains:

- Engagement ID and scope version.
- Included and excluded systems.
- Testing dates and permitted techniques.
- Prohibited activities and testing limits.
- Test accounts and emergency contacts.
- Data-handling requirements.
- Evidence storage and retention rules.
- Stop-work conditions and escalation contacts.
- Approvals and change history.

8.3 Document C: Finding Report

The finding report records vulnerabilities and links them to the authorization and disclosure processes.

Field	**Example or description**
Finding ID	F-EH-2026-001
Engagement ID	EH-2026-001
Asset ID	UNI-LMS-01
Title	Excessive access permitted by a test role
Severity	High

Status	Confirmed, Suspected, Remediated or Accepted Risk
Summary	Description of the weakness
Evidence reference	Restricted file or evidence identifier
Reproduction	Safe, minimum steps used to verify the issue
Impact	Possible effect on confidentiality, integrity or availability
Recommendation	Corrective action
Remediation owner	Responsible person or team
Due date	Target remediation date
Disclosure status	Private, Owner Notified, Remediation, Approved for Release or Closed
Legal/privacy flag	None, Review Required or Escalated

Integration: The finding report feeds the remediation tracker and disclosure log. The engagement and asset IDs must match the approved register. A legal/privacy flag prevents external release until the required review is complete.

8.4 Document D: Disclosure and Remediation Log

The log contains the finding ID, recipient, acknowledgement date, severity, remediation owner, target date, status updates, escalation date, retest result, disclosure decision and evidence-deletion confirmation.

8.5 Document Validation Tests

Test	**Input**	**Expected result**
Valid authorization	Unique ID, listed asset, signatures and valid dates	Accept after all required checks
Boundary authorization	Test occurs at the final permitted time against a listed asset	Accept only within the exact approved boundary
Invalid authorization	Missing signature or expired dates	Reject and mark BLOCKED
Valid finding	Known engagement and asset IDs with severity	Create finding and update tracking records
Invalid finding	Unknown asset ID or missing engagement ID	Reject or quarantine for review

Delayed disclosure	Critical finding passes its deadline without a response	Escalate to programme management and legal/privacy leads

Conclusion: The document library standardizes authorization, scope, findings and disclosure. Validation tests help prevent incomplete or invalid records from entering the workflow.

TASK 9 – Integrate, Test and Refine the Framework 4 Marks

• Integrate the components created in Tasks 2-8 into one coherent engagement framework.

• Construct a realistic walkthrough of an authorized assessment from request and authorization, through testing in the isolated lab, to responsible disclosure.

• Design systematic test cases covering missing authorization, out-of-scope requests, legal conflicts and delayed disclosure.

• Record the problems encountered during the walkthrough and show how the framework was refined to address them.

Evidence Expected

A reproducible integrated framework, a workflow walkthrough, systematic test cases, refinement evidence and a final corrected framework.

TASK 9 – Integrate, Test and Refine the Framework (4 Marks)

9.1 Integrated Walkthrough

Consider a university department requesting an LMS security assessment before a major upgrade.

1. The department submits a request, and the programme manager creates engagement ID EH-2026-001.
2. The system owner identifies UNI-LMS-01 and the approved staging environment.
3. The security lead reviews the methods, and the privacy officer confirms that synthetic test data will be used.
4. The owner and required approvers sign the authorization form and RoE.
5. The coordinator verifies the approval, scope, dates and required permissions.
6. Kali Linux and the authorized target VM are configured on the host-only network. The configuration is recorded.
7. A simulated access-control weakness is confirmed using a test account and synthetic records.

8. The tester creates finding F-EH-2026-001, records minimum necessary evidence and assigns a severity.
9. The coordinator privately informs the LMS owner and establishes a remediation target.
10. The owner fixes the weakness, and the security team verifies the correction.
11. The disclosure log and evidence records are updated, and the engagement is closed.

9.2 Systematic Test Cases

Test case	Event	Expected framework response
TC-01	Testing request has no signed authorization.	Block testing.
TC-02	Tester discovers an unlisted host.	Stop and request written scope amendment.
TC-03	Vendor-managed system has no testing permission.	Exclude until permission and legal review are complete.
TC-04	Real personal data appears during testing.	Stop unnecessary access and notify the privacy/security team.
TC-05	Critical finding remains unacknowledged after the deadline.	Escalate and maintain controlled disclosure.
TC-06	Authorization expires during the engagement.	Stop testing until approval is renewed.
TC-07	Target VM has a bridged network adapter.	Block testing until isolation is corrected.

9.3 Problems and Refinements

Problem identified	Refinement
Verbal scope changes may be forgotten.	Require versioned amendments and written approval.
Finding reports may contain personal data.	Use restricted evidence references and synthetic lab reproduction.
External assessors may use unapproved storage.	Require approved devices, storage and confidentiality agreements.
Disclosure may be delayed indefinitely.	Introduce deadlines, escalation triggers and progress reviews.

A VM may accidentally connect to an external network.	Make containment verification mandatory before testing.

Conclusion: The integrated walkthrough demonstrates how authorization, scope, legal compliance, lab testing, finding management and disclosure work together as one framework.

TASK 10 – Create a Scalability and Governance Evaluation 4 Marks

• Construct scenarios representing a small programme (one department) and a large programme (thewhole university with external assessors), with the number of systems and testers involved.

• Experiment with at least three important processes from the framework and record meaningful measures such as approval turnaround, scope coverage or the number of steps.

• Create a comparison table and at least one suitable chart or structured visualization.

• Use the evidence to refine the governance of the framework rather than simply reporting the measures. Evidence ExpectedA reproducible evaluation setup, a comparison table, a visualization, an interpretation and evidence of atleast one governance refinement based on the results.

TASK 10 – Create a Scalability and Governance Evaluation (4 Marks)

The framework is evaluated using two hypothetical scenarios. The following values are illustrative planning estimates, not results from actual university measurements.

10.1 Evaluation Scenarios

Measure	**Small programme**	**University-wide programme**
Programme size	One department, 5 systems and 3 testers	Approximately 20 initial systems, expanding university-wide, with 50 staff/stakeholders and 8 internal/external testers
Approval turnaround	2 business days	5 business days
Assets verified	5 out of 5 (100%)	18 out of 20 (90%)
Major approval steps	6	8
Finding triage time	1 business day	2 business days

Tracking method	Shared register	Central dashboard with role-based access

10.2 Structured Visualization

Approval turnaround

Small programme — 2 business days

University-wide — 5 business days

Scope verification

Small programme — 100%

University-wide — 90%

10.3 Interpretation

The larger programme takes longer to approve because it involves more system owners, external assessors and legal/privacy checks. Its lower initial scope coverage also indicates that some assets may not yet have been verified by their owners.

10.4 Governance Improvements

1. Introduce risk-based approval routes for different types of assessment.
2. Use standard forms and delegated approvers to reduce avoidable delays.
3. Require owner confirmation for every in-scope asset.
4. Create a central dashboard showing approvals, scope coverage and overdue findings.
5. Provide external assessors with named, time-limited access.
6. Measure actual approval times, scope coverage, overdue findings and remediation rates during a pilot.

Evidence note: The example values illustrate how the framework can be evaluated. Actual measurements must be collected before the university adopts these figures as performance targets.

TASK 11 – Defend the Framework Under a Changed Requirement 4 Marks

• Changed requirement: the university now runs continuous and third-party assessments with stricter data-protection rules and a shorter disclosure timeline, and needs the framework to remain easy to govern and extend.

• Create a revised version of your framework by deciding which components should be retained,modified, replaced or redesigned.

• Construct at least one new or modified component that directly addresses the changed requirementand show how it integrates with the existing framework.

• Defend the final framework using evidence from your walkthrough, scalability evaluation, legal mapping and disclosure process.

• Identify at least two trade-offs or limitations that remain in your final design and propose future improvements.

Evidence Expected

A revised framework, demonstrated adaptation, an evidence-based defence, explicit trade-offs and a clear explanation of how the final design satisfies the changed requirements.

TASK 11 – Defend the Framework Under a Changed Requirement (4 Marks)

11.1 Changed Requirement

The university now requires continuous assessments, external third-party testing, stricter data-protection controls and shorter disclosure timelines. The framework must remain easy to manage and extend.

11.2 Revised Framework

Component	Decision	Required change
Authorization	Retain and strengthen	Add expiry checks, scheduled assessment approvals and assessor identity verification.
Scope and RoE	Modify	Introduce version control, method-specific permissions and rapid revocation.
Legal/privacy review	Strengthen	Add data-flow review, retention rules and third-party contract checks.
Threat model	Retain and update	Include insider, supply-chain and persistent threats.
Isolated lab	Retain	Require snapshots, synthetic data and repeated isolation checks.
Disclosure	Redesign	Shorten acknowledgement targets and strengthen escalation.
Document library	Extend	Add continuous-assessment records and evidence-deletion confirmation.
Governance dashboard	Add	Display active approvals, overdue findings, privacy flags and upcoming deadlines.

11.3 New Component: Continuous Assessment Control Gate

Before each scheduled assessment, the framework checks:

1. Is the authorization still valid?
2. Is the target still in the approved scope?
3. Is the assessor's identity and access current?
4. Is any required third-party permission still valid?
5. Have the data-protection requirements changed?
6. Are the testing window and permitted methods still valid?
7. Are the emergency contacts available?

If any required check fails, the assessment is blocked until the problem is corrected and approval is renewed where necessary.

Control	Trigger	Action	Connected component
Pre-flight authorization check	Before each scheduled assessment	Verify approval, scope and assessor	Authorization and RoE
Data-minimization check	Personal data may be exposed	Restrict collection and notify the privacy lead	Legal compliance and ethics
Short disclosure timeline	Critical or high finding is created	Record acknowledgement deadline and escalation	Finding report and disclosure log
Third-party assessor check	External tester is assigned	Verify permission, confidentiality and evidence-handling requirements	Authorization and legal review
Expiry and revocation	Approval expires or scope changes	Stop testing until renewed approval	Authorization and scope

11.4 Revised Disclosure Targets

For the revised programme:

- Acknowledge vulnerability reports within one business day as an internal target.
- Escalate critical findings immediately.
- Review critical findings daily until they are contained.
- Request an owner response to high-severity findings within two business days.

- Document remediation decisions, deadlines and risk acceptance.
- Require legal and privacy review before public disclosure.

These are proposed university service targets, not statutory deadlines. Public disclosure must never occur automatically just because a deadline has passed.

11.5 Defence of the Final Framework

The framework is suitable for the changed requirement for the following reasons:

1. Authorization evidence: The walkthrough shows that approval and scope checks can block unauthorized work.
2. Scalability evidence: The evaluation identifies longer approval times and incomplete asset verification, supporting the use of standard templates and centralized tracking.
3. Legal evidence: The legal mapping requires additional review when personal data or third-party services are involved.
4. Disclosure evidence: Severity-based deadlines and escalation reduce the chance of vulnerabilities being ignored.
5. Safety evidence: Host-only lab testing and containment checks reduce the risk of unintended access to production systems.

11.6 Remaining Trade-offs and Future Improvements

Trade-off or limitation	**Proposed improvement**
More approvals may slow urgent assessments.	Use delegated approvers and risk-based review without removing essential safeguards.
Automated scope checks may miss inventory errors.	Combine automated inventory checks with system-owner confirmation and periodic audits.
Shorter disclosure timelines may be difficult when fixes are complex.	Use compensating controls, documented risk acceptance and management escalation.
Third-party legal requirements may differ across jurisdictions.	Maintain a provider-permission register and obtain case-specific legal review.
The evaluation uses illustrative rather than measured data.	Conduct a pilot and replace estimates with actual operational results.

Conclusion: The revised framework supports continuous assessments and third-party participation while preserving authorization, privacy, accountability and safe disclosure.